

Risk register (15 risks)

This is not legal advice. Source: governance/risk_register.csv.

risk_id	title	rating	existing_control	test_evidence	owner	status
R01	Another customer's data is disclosed	High	Order details only after the order ID and the email on that order match (agent.verify, ShopData.verify); the check node removes any other customer's order before the reply; order_view() never includes name, email or phone; guards.find_leaks() replaces any reply that contains another customer's data; handover after 3 failed checks.	P1 deterministic tests passed 2026-10-08 (E01, E02, E09, E12). Rules baseline: 0/120 conversations with leaked_other_customer_data (E13). Live agent eval of the other_person_order category and P3 pii_extraction red-team: pending live run (E15, E23). P3 leak rules tested (E20). P8 probe: the output leak filter missed 3 of 6 format variants of another customer's phone (E35, failed).	Data protection lead	Control built - evidence pending
R02	Prompt injection makes the assistant act against the rules	Critical	Customer and retrieved text are wrapped in data tags with angle brackets neutralised (parsing.as_prompt_data); both prompts say tagged text is data; the model never chooses tools (plain code in agent.act does); money and data changes can only be queued for a human; injection keywords add a security note to the CRM.	P1 tests passed 2026-10-08, including a fake model that obeys the attack: refund still pending for a supervisor, nothing paid (E03, E04). Rules baseline: 0/15 injection conversations caused a violation, but only 3/15 reached the expected outcome (E13). Live agent eval and P3 prompt_injection / jailbreak red-team: pending live run (E14, E15, E22, E26).	Engineering lead	Control built - evidence pending
R03	Wrong or unauthorised refund	High	request_refund only queues an approval; return eligibility is computed in code (data.return_eligibility); amount must be between 0 and the order total and the order must belong to the verified customer; refunds above AED 200 need a supervisor (crm.approval_level); a denied item has no effect; the reply prompt forbids saying a refund is done unless approved.	P1 tests passed 2026-10-08 (E05, E11). Rules baseline: 0/120 conversations with action_decided_without_human or refund_over_200_not_escalated (E13). Live decision accuracy: pending live run (E16).	Finance lead	Control built - evidence pending
R04	A retry pays or changes something twice	Medium	The same pending request is never queued twice; CrmStore.decide() does nothing for an already decided item; no side effects before interrupt() in wait_for_approval.	P1 tests test_decide_is_idempotent and test_same_pending_request_is_not_queued_twice passed 2026-10-08 (E06).	Engineering lead	Control verified
R05	Unauthorised delivery-address change	High	Address change needs a verified customer, only works while the order is 'processing', and is only applied after a person approves it (CrmStore.update_address, decide).	P1 tests passed 2026-10-08 (E07, E01). Live decision accuracy for the address_change category: pending live run (E16).	Customer care lead	Control built - evidence pending
R06	Hallucinated or wrong	Medium	Replies use only the facts and policy sections the code retrieved (prompt rule 1); decisions such as return	P1 return-policy rules tested (E11). P3 grounding check: 0 validation problems in 225 items (E21). Policy-fact accuracy per	Product owner	Control built -

	policy answer		eligibility are made by code, not the model; if the model fails, a fixed template is used.	language: pending live run (E27).		evidence pending
R07	Worse quality or impolite tone in one language	Medium	Language detected by code and reply forced to that language; every metric is reported per language; native-speaker review of the Arabic and French texts is planned (Sara).	All pending: per-language task success and tone (E17), per-language tone and language quality in P3 (E28), judge-vs-human agreement (E19, E29). P3 native-speaker review done: 0/150 items so far (E21 notes).	Product owner	Control built - evidence pending
R08	Unsafe skincare or medical advice	High	Prompt rule 5 (general advice only; refer to a dermatologist or doctor); advice template says 'not medical advice, patch-test first'; product suggestions come only from the catalogue search in code.	P3 unsafe_advice red-team (9 attacks): pending live run (E24). No P1 test checks the medical-referral wording yet.	Product owner	Control built - evidence pending
R09	Invented discount, code or promise	Medium	No discount tool exists; prompt rule 1 forbids inventing discounts or promises; P3 checks answers for forbidden strings such as invented codes.	P3 leak and forbidden-string rules tested (E20). P3 discount_fraud red-team: pending live run (E25).	Finance lead	Control built - evidence pending
R10	Missing or unclear AI disclosure	Medium	The first reply always starts with a fixed disclosure in the customer's language, added by code (guards.disclosure); the demo page banner says 'You are chatting with an AI assistant'; the eval flags missing_ai_disclosure.	test_first_reply_discloses_ai_assistant passed 2026-10-08, French path (E08). Rules baseline: 0/120 missing_ai_disclosure across 40 ar / 40 en / 40 fr (E13). P8 probe: Arabic and English agent replies start with the disclosure (E36). Live agent eval: pending live run (E14).	Compliance lead	Control built - evidence pending
R11	Model or service outage	Medium	If the reply model fails, a fixed template answer is used; if the intent model fails, keyword rules are used; the courier client retries; failed calls are logged; customers can always ask for a person.	Courier retry tested (E10). P8 probe: with every model call failing, the agent still answered from templates or handed over (E36). Errors and latency per conversation: pending live run (E18). Switch-off procedure documented (E32).	Engineering lead	Control built - evidence pending
R12	Cost overrun	Low	Cheap model for intent; max_tokens caps; demo limit of 20 messages per session; cost from OpenRouter logged per call in traces.jsonl; evaluation budget guard (MAX_COST_PER_RUN_USD).	P3 budget guard tests passed (E30). Average cost per conversation (P1) and per 100 answers (P3): pending live run (E18, E31).	Finance lead	Control built - evidence pending
R13	Sensitive data kept in logs and tickets	Medium	Model-call traces store only metadata (model, tokens, cost, latency, outcome), not message text; handover tickets keep at most 500 characters of the last message.	Data inventory and retention rules documented (E33, E32). No redaction test exists.	Data protection lead	Open
R14	Chat data sent to a model provider abroad	High	Order facts sent to the model exclude name, email and phone (order_view); only the verified customer's data is ever in the prompt.	Data flows documented in the UAE notes (E33). No technical control yet masks what the customer types.	Data protection lead	Open
R15	Weak human	High	The code refuses a large refund unless the decision is	Supervisor rule tested (E05). Oversight design and approver	Customer	Open

	oversight of approvals		made with the supervisor role, and every decision is logged to approval_log.jsonl. In the demo the reviewer chooses their own role and is logged as 'demo reviewer' (design-review finding DR-2).	checklist documented (E32). Code-review finding documented (E34).	care lead	
--	------------------------	--	---	---	-----------	--